

IBVAP — Security Audit & Code Vulnerability Review

12. Security Review & Vulnerability Assessment

1. Security Audit Matrix

Category	Finding / Pattern Checked	Risk Level	Status / Mitigation
Credentials	Hardcoded passwords, API keys, or DB URIs	HIGH	PASSED: All DB connection URIs are dynamically fetched via <code>os.environ</code> or <code>st.secrets</code> . No plain-text passwords committed in source code.
TLS Verification	MongoDB Atlas SSL/TLS Connection	MEDIUM	PASSED: Uses <code>certifi.where()</code> for CA certificate bundle validation to prevent MITM attacks on database traffic.
Database Injection	MongoDB / Supabase queries	LOW	PASSED: Queries use parameter dictionary objects (<code>{"event_id": event.event_id}</code>) preventing raw query string injection.
HTML Injection	<code>st.markdown(..., unsafe_allow_html=True)</code>	LOW	MITIGATED: Used extensively for UI styling. Inputs rendered inside HTML components are sanitized string casts of system metrics or controlled DB strings.
Path Traversal	Evidence file loading (<code>fetch_image_bytes</code>)	LOW	MITIGATED: File access restricted to internal <code>output/</code> directory paths or validated <code>http://https://</code> URLs.
Error Leakage	Exception stack trace printing	INFO	OBSERVED: Errors printed to server console via <code>print()</code> statements for operational debugging during prototype evaluation.

2. Detailed Findings by Category

A. Secrets & Credential Storage (**PASSED**)

Inspection of `src/app.py` (Lines 83–96) and `streamlit_app/utils/data_service.py` (Lines 19–20) verifies that database connection strings are never hardcoded.

```
# VERIFIED SAFE PATTERN
SUPABASE_URL = os.environ.get("SUPABASE_URL") or os.environ.get("VITE_SUPABASE_URL", "")
SUPABASE_KEY = os.environ.get("SUPABASE_ANON_KEY") or os.environ.get("VITE_SUPABASE_ANON_KEY", "")
```

B. Database Security & Permissions (**PASSED**)

- MongoDB Atlas connection uses `serverSelectionTimeoutMS=10000` to prevent thread hanging during network failure.
- Database access is scoped to database `IBVAP` and collection `intrusion_events`.

C. HTML Injection & Cross-Site Scripting (XSS) (**MITIGATED**)

- Streamlit's `unsafe_allow_html=True` is leveraged to achieve custom dark navy styling and custom SVG icons.
- All user-controllable inputs (such as search boxes) are processed in Streamlit python state and filtered using standard Python list operations, preventing script injection into the browser DOM.

3. Recommended Security Hardening for Enterprise Deployment

- **Authentication & Role-Based Access Control (RBAC):** Implement user login authentication (Streamlit-Authenticator / OAuth2) to restrict Command Center access to authorized military personnel.
- **API Endpoint Rate Limiting:** Apply rate limiting on video upload or database sync endpoints.
- **Hardware Security Module (HSM):** Store the SHA-256 root hash in a hardware-backed security key or digital signature vault.